SIZMA TESTİ RAPORU

Rapor Tarihi	13/10/2026
Hazırlayan	Ömer Faruk Baysal
Test Hedefi	PortSwigger Web Academy Lab

1. Information disclosure vulnerabilities

Bu raporda, PortSwigger Web Security Academy'de yer alan Information disclosure (Bilgi İfşası) konusuyla ilgili beş farklı durum tek bir bulgu altında ele alınmıştır.

2. Yönetici Özeti

Yapılan güvenlik testinde hedef uygulamanın hassas bilgileri yetkisiz kullanıcılara ifşa ettiği beş farklı durum tespit edilmiştir. İfşa edilen bilgiler; çatı (framework) sürümü, gizli ortam değişkenleri, kaynak kodundaki veritabanı kimlik bilgileri, ön yüzün eklediği özel bir yetkilendirme başlığı ve sürüm kontrol geçmişinde kalan yönetici parolasıdır. Bu ifşaların bir kısmı tek başına bilgi sızıntısıyla sınırlı kalırken, bir kısmı doğrudan yönetici hesabının ele geçirilmesine ve yetkisiz işlemlerin (kullanıcı silme) gerçekleştirilmesine kadar ilerleyebilmektedir. Sistem bütünlüğünü tümüyle tehlikeye atabilecek bu zafiyetlerin ivedilikle giderilmesi önerilmektedir.

3. Zafiyet Açıklaması

Durum 1: Information disclosure in error messages

Hedef uygulamada yapılan testler sonucunda ürün sayfasının isteğinde yer alan productID değerinin rastgele bir şekilde geçersiz bir değerle değiştirildiğinde hata yanıtı olarak sunucu yanıtlarının da döndürüldüğü gözlemlenmiştir.

Durum 2: Information disclosure on debug page

Hedef uygulamada yapılan testler sonucunda ürün sayfasının yanıtında yorum satırına alınmış bir yönlendirme uzantısı tespit edilmiştir. Bu yönlendirme kullanılarak sunucu ile ilgili hassas verilerin içerdiği sayfaya erişilebildiği PoC adımlarıyla kanıtlanmıştır.

Durum 3: Source code disclosure via backup files

Hedef uygulamada url kısmından doğrudan robots.txt dosyasına erişim ile birlikte gizli bir backup sayfasının yer aldığı ve bu sayfada yer alan java dosyasında da veritabanı ile ilgili hassas bilgilerin yer aldığı PoC adımlarıyla kanıtlanmıştır.

Durum 4: Authentication bypass via information disclosure

Yapılan testler sonucunda /admin uzantısından metod değişikliği ile (GET->TRACE) yetkisiz kullanıcının yetkili paneline erişebildiği ve yetkili işlemleri yapabildiği PoC adımlarıyla kanıtlanmıştır.

Durum 5: Information disclosure in version control history

Yapılan testler sonucunda git dosyasına erişilebildiği ve burada yer alan log geçmişinden yetkili hesabının şifresine erişim sağlanabildiği, bu sayede yetkili işlemleri yapabildiği PoC adımlarıyla kanıtlanmıştır.

4. Risk Seviyesi

Risk Seviyesi	Kritik
CVSS v3.1 Skoru	9.1
CVSS v3.1 Vektörü	AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:N
CWE	CWE-200 (Exposure of Sensitive Information to an Unauthorized Actor)

5. Etki

Yapılan testler sonucunda oluşan zafiyetler sayesinde saldırgan, uygulama ve altyapısıyla ilgili hassas bilgilere yetkisiz biçimde erişebilmektedir.

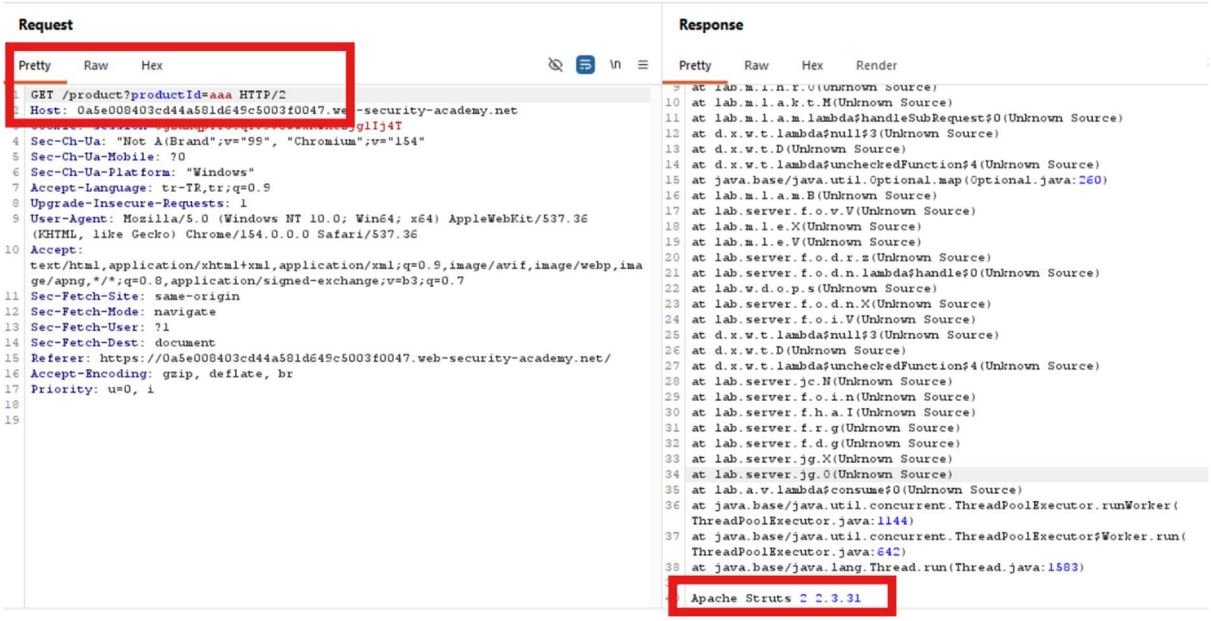
Doğrudan etki, çatı sürüm bilgisinin, gizli bir SECRET_KEY değerinin, kaynak kodundaki veritabanı kimlik bilgilerinin ve yönetici parolasının okunabilmesi; ayrıca ön yüzün eklediği özel başlığın ele geçirilmesiyle yönetici paneline erişilip bir kullanıcının (carlos) silinebilmesidir.

Potansiyel etki, ifşa edilen sürüm bilgisiyle bilinen güvenlik açıklarının hedeflenmesi, elde edilen veritabanı/yönetici kimlik bilgileriyle sistemdeki tüm verilere ve işlevlere kalıcı erişim sağlanması ve sistemin tümüyle ele geçirilmesidir.

6. Proof Of Concept

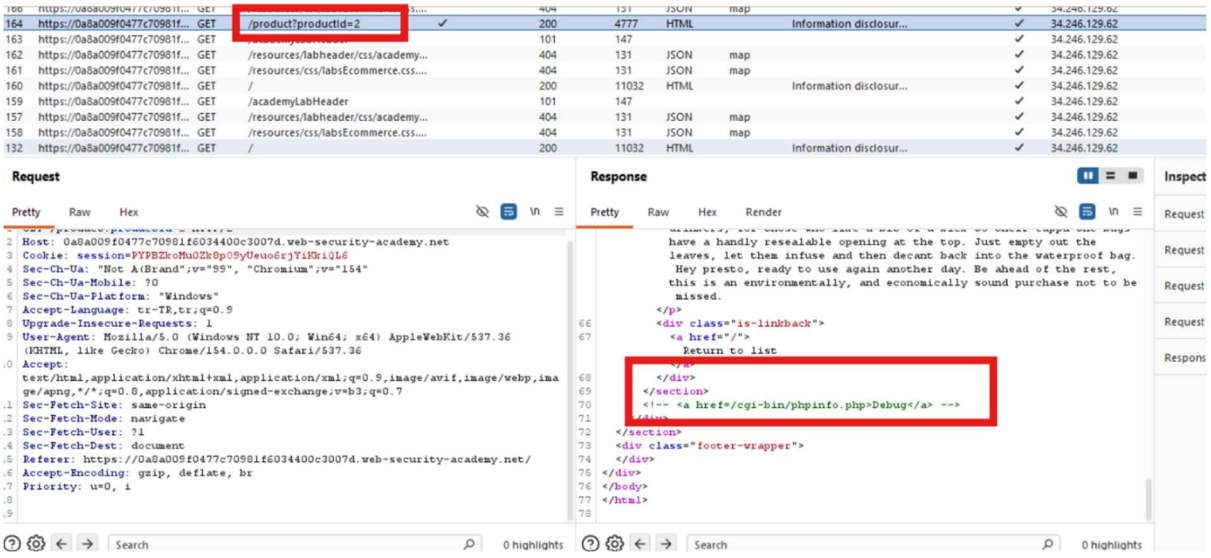
Durum 1: Information disclosure in error messages

Hedef sitedeki ürün sayfası incelendiğinde ilgili metodda yer alan productId değerinin rastgele bir değer ile değiştirildiğinde yanıt olarak sunucu hatalarını da döndürdüğü gözlemlenmiştir. Bu sayede test için erişilmesi istenen sunucu versiyonuna da bu şekilde ulaşılabilmektedir.

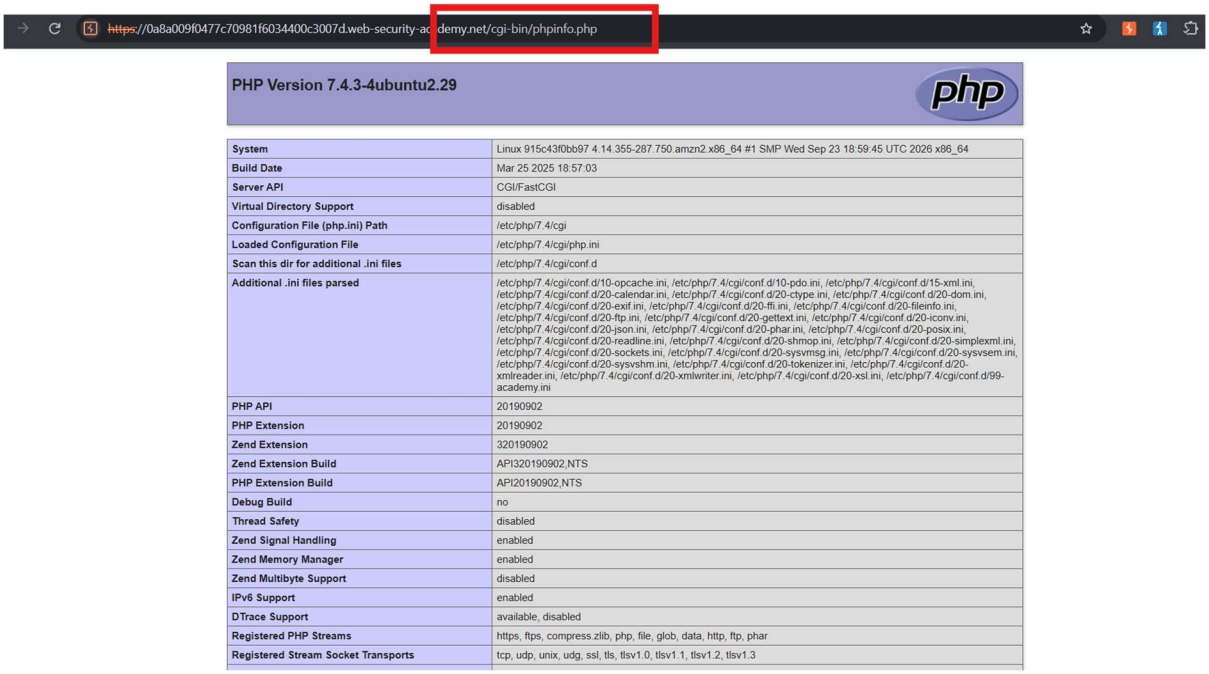


Durum 2: Information disclosure on debug page

Hedef sitede yer alan ürün sayfasındaki yanıt incelendiğinde en alt satırlara doğru yorum satırı içine alınmış bir uzantı görülmektedir.



Bu uzantı kullanılarak tarayıcıda php sunucu sayfasına erişilebilmektedir.



System	Linux 915c43f0bb97 4.14.355-287.750.amzn2.x86_64 #1 SMP Wed Sep 23 18:59:45 UTC 2026 x86_64
Build Date	Mar 25 2025 18:57:03
Server API	CGI/FastCGI
Virtual Directory Support	disabled
Configuration File (php.ini) Path	/etc/php/7.4/cgi
Loaded Configuration File	/etc/php/7.4/cgi/php.ini
Scan this dir for additional .ini files	/etc/php/7.4/cgi/conf.d
Additional .ini files parsed	/etc/php/7.4/cgi/conf.d/10-opcache.ini, /etc/php/7.4/cgi/conf.d/10-pdo.ini, /etc/php/7.4/cgi/conf.d/15-xml.ini, /etc/php/7.4/cgi/conf.d/20-calendar.ini, /etc/php/7.4/cgi/conf.d/20-ctype.ini, /etc/php/7.4/cgi/conf.d/20-dom.ini, /etc/php/7.4/cgi/conf.d/20-exif.ini, /etc/php/7.4/cgi/conf.d/20-ffi.ini, /etc/php/7.4/cgi/conf.d/20-fileinfo.ini, /etc/php/7.4/cgi/conf.d/20-ftp.ini, /etc/php/7.4/cgi/conf.d/20-gettext.ini, /etc/php/7.4/cgi/conf.d/20-iconv.ini, /etc/php/7.4/cgi/conf.d/20-json.ini, /etc/php/7.4/cgi/conf.d/20-phar.ini, /etc/php/7.4/cgi/conf.d/20-posix.ini, /etc/php/7.4/cgi/conf.d/20-readline.ini, /etc/php/7.4/cgi/conf.d/20-shmop.ini, /etc/php/7.4/cgi/conf.d/20-simplexml.ini, /etc/php/7.4/cgi/conf.d/20-sockets.ini, /etc/php/7.4/cgi/conf.d/20-sysvmsg.ini, /etc/php/7.4/cgi/conf.d/20-sysvsem.ini, /etc/php/7.4/cgi/conf.d/20-sysvshm.ini, /etc/php/7.4/cgi/conf.d/20-tokenizer.ini, /etc/php/7.4/cgi/conf.d/20-xmlreader.ini, /etc/php/7.4/cgi/conf.d/20-xmlwriter.ini, /etc/php/7.4/cgi/conf.d/20-xsl.ini, /etc/php/7.4/cgi/conf.d/99-academy.ini
PHP API	20190902
PHP Extension	20190902
Zend Extension	320190902
Zend Extension Build	API320190902,NTS
PHP Extension Build	API20190902,NTS
Debug Build	no
Thread Safety	disabled
Zend Signal Handling	enabled
Zend Memory Manager	enabled
Zend Multibyte Support	disabled
IPv6 Support	enabled
DTrace Support	available, disabled
Registered PHP Streams	https, ftps, compress.zlib, php, file, glob, data, http, ftp, phar
Registered Stream Socket Transports	tcp, udp, unix, udg, ssl, tls, tlsv1.0, tlsv1.1, tlsv1.2, tlsv1.3

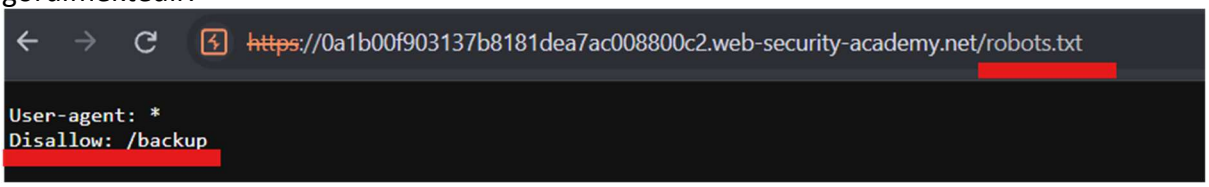
Test için istenen SECRET_KEY değeri de burada yer almaktadır.

Environment

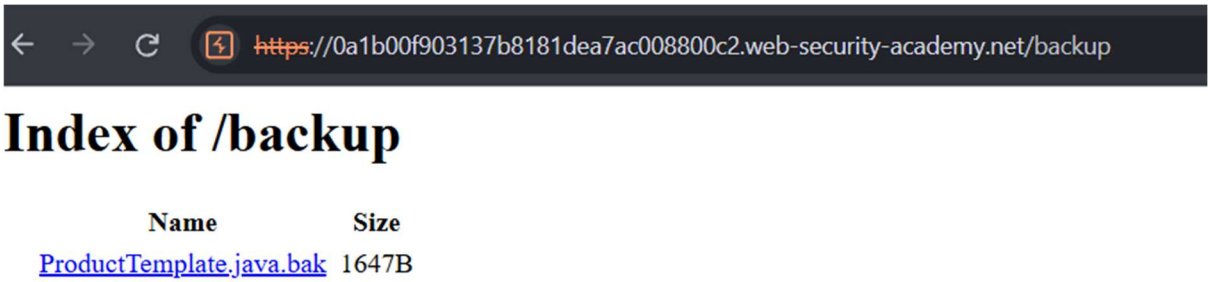
Variable	Value
GATEWAY_INTERFACE	CGI/1.1
SUDO_GID	10000
REMOTE_HOST	176.41.57.149
USER	carlos
HTTP_SEC_CH_UA	"Not A(Brand";v="99", "Chromium";v="154"
SECRET_KEY	o3q9fbynaicff3rgan6gv73t0nizo3xy
HTTP_SEC_FETCH_USER	?1
QUERY_STRING	*no value*
HOME	/home/carlos
HTTP_USER_AGENT	Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/154.0.0.0 Safari/537.36
HTTP_SEC_CH_UA_PLATFORM	"Windows"
HTTP_UPGRADE_INSECURE_REQUESTS	1
HTTP_ACCEPT	text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/sign

Durum 3: Source code disclosure via backup files

Hedef site uzantısına /robots.txt eklenip test edildiğinde /backup uzantısının olduğu görülmektedir.



Bu sayfaya erişildiğinde java dosyasıyla karşılaşılmaktadır.



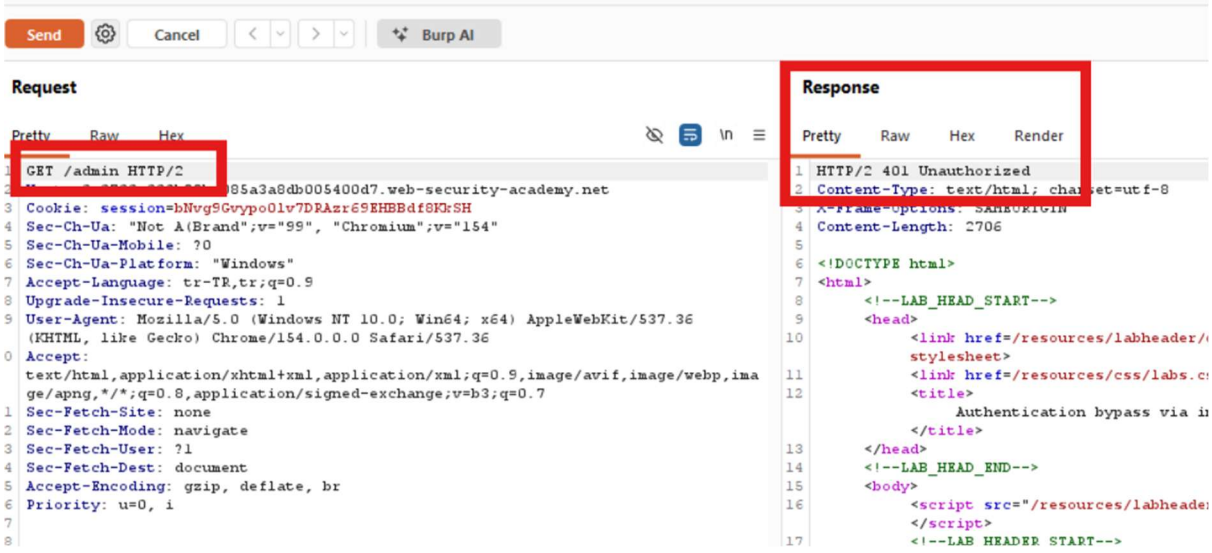
Bu dosya incelendiğinde veritabanı ile ilgili kısımların varlığı görülmektedir. Buradan çeşitli bilgiler elde edilebilmektedir. Test için veritabanı şifresi de burada yer almaktadır.

```
private void readObject(ObjectInputStream inputStream) throws IOException, ClassNotFoundException
{
    inputStream.defaultReadObject();

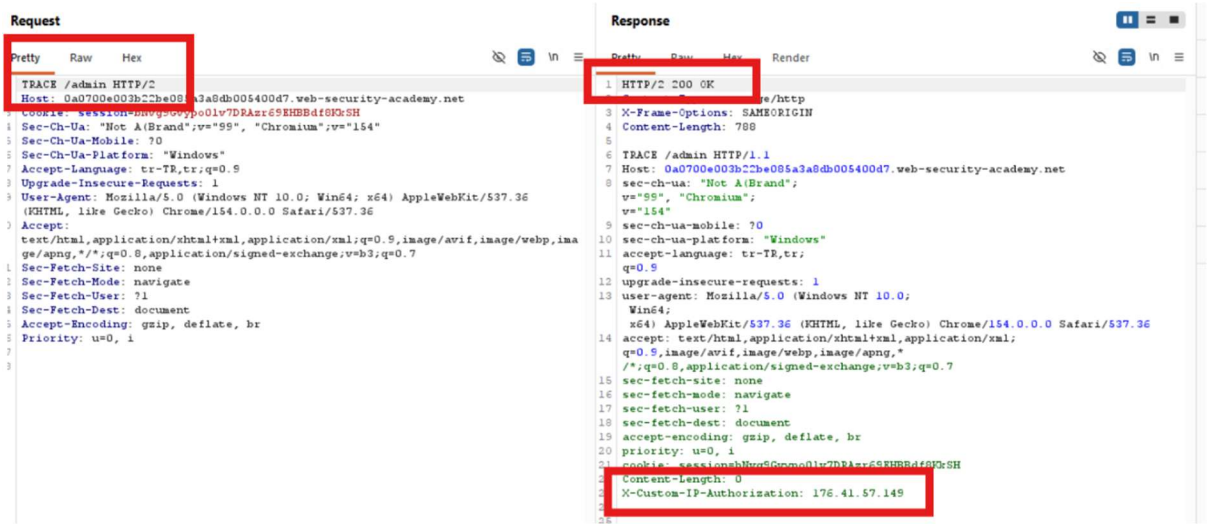
    ConnectionBuilder connectionBuilder = ConnectionBuilder.from(
            "org.postgresql.Driver",
            "postgresql",
            "localhost",
            5432,
            "postgres",
            "npx74refnuuqi3ec1tc09nkyvp9jhfji"
    ).with
```

Durum 4: Authentication bypass via information disclosure

Hedef sitede /admin uzantısı test edildiğinde 401 yetkisiz erişim hatası alınmaktadır.



Buradaki GET metodu TRACE ile değiştirildiğinde X-Custım-IP-Authorization başlığı ile



karşılaşılmaktadır. Bu başlık tekrar GET metoduna eklenip buradaki ip adresi de 127.0.0.1 (yerel ağ adresi) yapıldığında admin sayfasına başarıyla erişim sağlanabilmektedir.

Admin sayfası incelendiğinde test hedefi olan carlos kullanıcısını silme işlemi ile ilgili olan uzantı da yer almaktadır. Bu uzantı ilgili metodda kullanılıp istek gönderildiğinde hedef kullanıcı başarıyla silinebilmektedir.

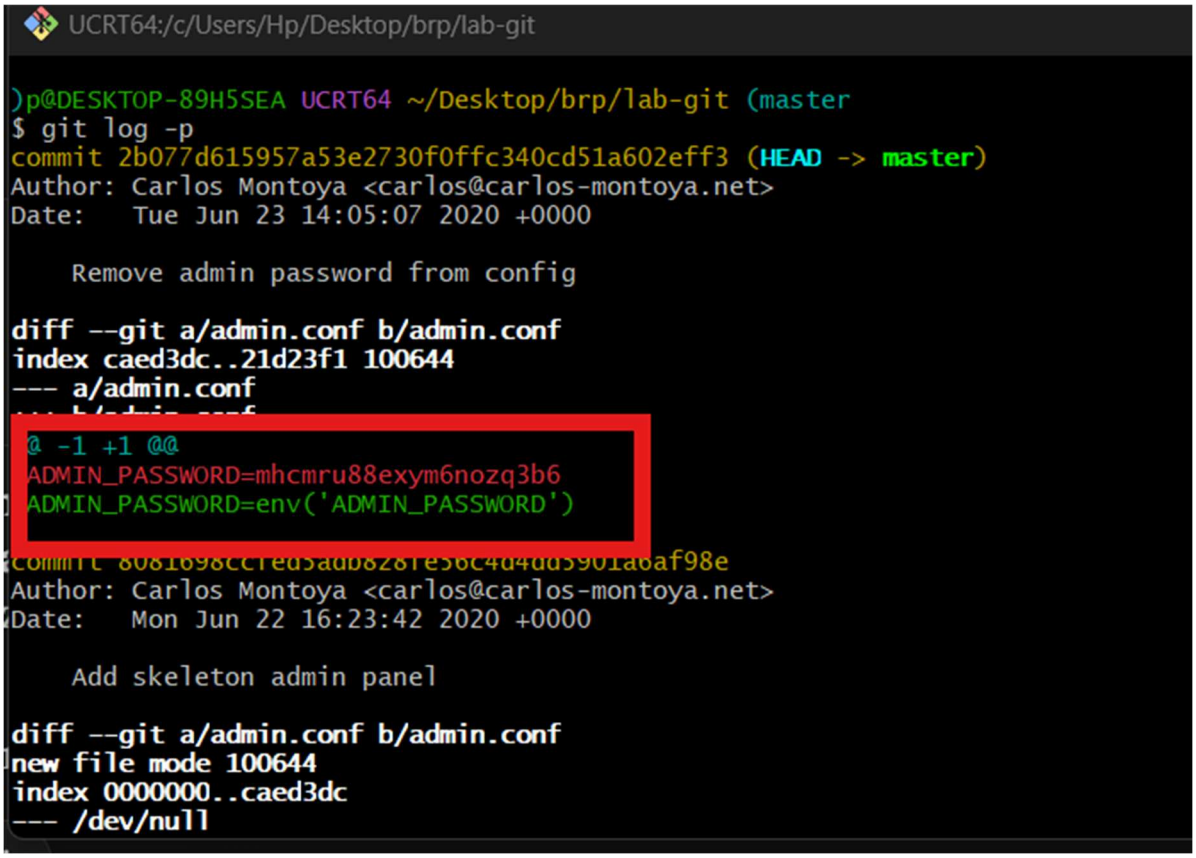
```
            </a>
        </div>
        <div>
            <span>
                carlos -
            </span>
            <a href="/admin/delete?username=carlos">
                Delete
            </a>
        </div>
</section>
<br>
<hr>
```

Durum 5: Information disclosure in version control history

Hedef sitede git kontrolü yapıldığında /.git uzantısına erişilebildiği tespit edilmiştir.



Terminalden bu git git dosyası indirilip ilgili komutlarla log geçmişi incelendiğinde yetkili şifresine ulaşılabilmektedir.



Böylelikle yetkili hesabına giriş yapılabilmektedir ve test için istenen kullanıcı silinebilmektedir.

7. Çözüm Önerisi

Genel ilke olarak, hassas hiçbir bilgi istemciye ya da dışarıdan erişilebilir konumlara bırakılmamalı, en az bilgi prensibi uygulanmalıdır. Durum bazında:

- Hata mesajları: Üretim ortamında ayrıntılı hata çıktıları ve stack trace'ler istemciye gösterilmemeli; hatalar sunucu tarafında loglanıp kullanıcıya yalnızca genel bir hata sayfası dönülmelidir.
- Debug sayfası: phpinfo benzeri hata ayıklama sayfaları üretim ortamından kaldırılmalı; HTML yorum satırlarında iç yollar, dosya adları veya uç nokta bilgileri bırakılmamalıdır.
- Yedek dosyalar: Yedek ve kaynak dosyalar web kök dizininde tutulmamalı, dizin listeleme kapatılmalıdır. robots.txt bir gizlilik aracı değildir; hassas yolları orada belirtmek erişimi engellemek yerine ifşa eder. Kimlik bilgileri koda gömülmemeli, güvenli bir sır yönetimi (ortam değişkeni) kullanılmalıdır.
- Kimlik doğrulama atlatma (TRACE): Gereksiz HTTP metotları (özellikle TRACE) sunucuda devre dışı bırakılmalı; yetkilendirme asla istemcinin gönderebileceği/sahteleyebileceği başlıklara ya da IP değerlerine dayandırılmamalı, her istekte sunucu tarafında oturum üzerinden doğrulanmalıdır.
- Sürüm kontrol geçmişi: .git gibi sürüm kontrol dizinleri web sunucusu üzerinden erişime kapatılmalıdır. Sırlar hiçbir zaman commit geçmişine girmemeli; girdiyse ilgili tüm kimlik bilgileri (parola, anahtar) derhal değiştirilmeli ve geçmişten temizlenmelidir.

8. Sonuç

Yapılan testler sonucunda hedef uygulamanın beş farklı biçimde hassas bilgi ifşa ettiği ve bu ifşaların bir kısmının doğrudan yönetici hesabının ele geçirilmesine kadar ilerleyebildiği doğrulanmıştır.

Zafiyet, sistemin tümüyle ele geçirilmesine kadar ilerleyebilecek etkisi nedeniyle kritik risk seviyesinde değerlendirilmiş olup, önerilen önlemlerin uygulanarak ivedilikle giderilmesi tavsiye edilmektedir.